

1. Políticas Generales y de Cumplimiento Financiero

Antes de abordar la tecnología, es necesario establecer el marco de conducta humana y regulatoria sobre el cual se asienta la empresa.

Prevención de Lavado de Activos y Financiamiento del Terrorismo (PLA/FT): Obligatoriedad de los procesos de "Conozca a su Cliente" (KYC) y "Conozca a su Empleado" (KYE). Reporte de operaciones sospechosas (ROS).

Código de Ética y Conflicto de Intereses: Prohibición de operar con información privilegiada (Insider Trading), aceptación de regalos y manejo de cuentas de familiares.

Continuidad del Negocio (BCP): Protocolos de actuación humana y financiera ante desastres naturales, pandemias o caídas masivas de los sistemas centrales (Core Bancario).

2. Políticas Específicas de Seguridad de la Información

Este es el núcleo de tu estrategia. Cada empleado, desde la gerencia hasta atención al cliente, debe firmar un acuerdo de conformidad con estos lineamientos.

2.1 Control de Acceso y Gestión de Identidades (IAM)

El acceso a los sistemas debe estar basado en la premisa de que ningún usuario necesita ver todo.

Principio de Menor Privilegio (PoLP): Los colaboradores solo tendrán acceso a los módulos y datos estrictamente necesarios para su rol.

Autenticación Multifactor (MFA): Obligatoria para todos los accesos al sistema central, VPNs y correo electrónico corporativo.

Gestión de Credenciales: Las contraseñas deben rotarse cada 90 días, tener un mínimo de 12 caracteres (incluyendo alfanuméricos y símbolos) y no repetirse. Las cuentas de usuarios inactivos o desvinculados deben revocarse en un plazo máximo de 15 minutos tras la notificación de RR.HH.

2.2 Clasificación y Tratamiento de la Información

No todos los datos tienen el mismo valor. La política debe definir cómo se maneja cada tipo de documento o base de datos.

Pública: Información de libre circulación (ej. folletos de tasas de interés).

Uso Interno: Manuales de procedimientos y organigramas.

Confidencial: Datos de clientes, saldos de cuentas, historial crediticio. Obligación: Debe estar cifrada en tránsito (TLS 1.2+) y en reposo (AES-256). Solo puede enviarse por canales corporativos.

Restringida: Códigos fuente, llaves criptográficas, bases de datos completas, estrategias de fusiones. Obligación: Acceso limitado a alta gerencia y administradores de TI bajo auditoría estricta.

2.3 Uso Aceptable de Activos (AUP)

Establece las reglas de juego sobre los equipos proporcionados por la empresa.

Bloqueo de Periféricos: Los puertos USB de las computadoras deben estar bloqueados mediante software (DLP - Data Loss Prevention) para evitar la extracción de información en memorias externas.

Navegación y Correo: Prohibición de uso del correo corporativo para registros personales. Bloqueo a nivel de proxy de sitios web de alto riesgo (juegos, torrents, webmail personal).

Instalación de Software: Los usuarios no deben tener privilegios de administrador en sus equipos. Todo software debe ser instalado y aprobado por el área de TI.

2.4 Seguridad Física y Entorno de Trabajo

La ciberseguridad falla si alguien puede simplemente entrar a la oficina y robar un disco duro o leer una pantalla.

Escritorio y Pantalla Limpia (Clean Desk / Clean Screen): Ningún documento con información de clientes (contratos, cheques) debe quedar sobre los escritorios al finalizar la jornada. Las computadoras deben bloquearse automáticamente tras 5 minutos de inactividad.

Zonas Restringidas: El acceso al Centro de Procesamiento de Datos (CPD) o archivo de bóveda requiere autenticación biométrica y registro en bitácora.

2.5 Trabajo Remoto y Dispositivos Móviles (BYOD)

El perímetro de la empresa ahora se extiende a la casa de los empleados.

Conexiones Seguras: Todo trabajo remoto debe realizarse a través de una VPN con túnel cifrado completo (Full Tunnel). Prohibido el uso de redes Wi-Fi públicas abiertas.

Gestión de Dispositivos (MDM): Si los empleados usan sus teléfonos para acceder al correo del banco, el dispositivo debe tener instalado un software de gestión (MDM) que permita el borrado remoto de los datos corporativos en caso de pérdida o robo.

2.6 Gestión de Riesgos de Terceros

Un banco es tan seguro como su proveedor menos seguro.

Auditoría de Proveedores: Todo proveedor que tenga acceso a la red de la empresa o a datos de clientes (ej. procesadoras de tarjetas, empresas de cobranza) debe someterse a una auditoría de seguridad anual y firmar Acuerdos de Confidencialidad (NDA).

3. Gestión de Incidentes y Régimen Disciplinario

La política debe establecer qué hacer cuando las cosas salen mal y cuáles son las consecuencias de incumplir las reglas.

Obligación de Reporte: Todo empleado debe reportar inmediatamente al Centro de Operaciones de Seguridad (SOC) o a TI cualquier anomalía: pérdida de un equipo, correos sospechosos (phishing) o comportamientos inusuales del sistema.

Capacitación Continua: Pruebas obligatorias y recurrentes de ingeniería social (simulacros de phishing).

Sanciones: Clasificar las faltas en leves, graves y muy graves (ej. enviar una base de datos a un correo personal). Las faltas muy graves en el sector financiero suelen ser causal de despido justificado y, potencialmente, de acciones legales conjuntas con los reguladores.

4. Políticas de Recursos Humanos y Gestión del Talento

4.1 Reclutamiento y Onboarding Seguro

El proceso de selección en una entidad financiera debe garantizar que se contrata a personal confiable antes de otorgarles acceso a la infraestructura crítica.

Verificación de Antecedentes (Background Checks): Para posiciones sensibles, RR.HH. debe verificar antecedentes penales, referencias laborales previas y el historial crediticio del candidato (un alto nivel de sobreendeudamiento puede considerarse un riesgo de fraude interno).

Firma de Acuerdos Previos: Antes de la entrega de equipos o creación de usuarios en el sistema, el nuevo empleado debe firmar el Acuerdo de Confidencialidad (NDA), el Código de Ética y el documento de Uso Aceptable de Activos (AUP).

Capacitación de Día Cero: El acceso a los sistemas centrales (Core Bancario, bases de datos de clientes) no se habilitará hasta que el empleado complete y apruebe el módulo introductorio de Seguridad de la Información y Prevención de Lavado de Activos.

4.2 Control de Funciones y Vacaciones (Antifraude)

Las políticas de tiempo libre en el sector financiero no solo responden al bienestar, sino que son controles de auditoría.

Vacaciones Ininterrumpidas Obligatorias (Block Leave): Los empleados con roles transaccionales, de tesorería o con privilegios elevados en sistemas deben tomar un mínimo de 10 a 14 días de vacaciones continuas al año. Durante este periodo, se revoca temporalmente su acceso a los sistemas para que otro empleado asuma sus funciones, permitiendo descubrir posibles fraudes ocultos o procesos irregulares.

Segregación de Funciones (SoD): Ningún empleado debe tener el control de principio a fin sobre una transacción financiera importante. El proceso de creación, aprobación y ejecución debe recaer en personas distintas.

4.3 Desempeño, Cultura y Bienestar Laboral

El estado físico y mental del equipo impacta directamente en la seguridad. Un empleado fatigado o desmotivado es más propenso a cometer errores operativos o caer en ataques de ingeniería social.

Evaluación de Cumplimiento: El respeto a las normas de ciberseguridad (ej. reportar correos sospechosos, no dejar la pantalla desbloqueada, aprobar cursos de InfoSec) debe ponderar al menos un 10% en la evaluación de desempeño anual para el cálculo de bonos.

Gestión de la Fatiga: Monitoreo estricto de las horas extras. En áreas críticas como el Centro de Operaciones de Seguridad (SOC) o Infraestructura TI, se deben establecer límites de horas de guardia para evitar errores de configuración críticos por agotamiento.

Canal de Denuncias Anónimo (Whistleblowing): RR.HH. debe administrar una plataforma segura, confidencial y gestionada por un tercero, para que los empleados denuncien fraudes, acoso laboral o violaciones de seguridad sin miedo a represalias.

4.4 Offboarding y Cese de Funciones

La desvinculación de un empleado (renuncia o despido) es el momento de mayor riesgo para la fuga de información corporativa.

Notificación en Tiempo Real: RR.HH. debe notificar al área de TI de forma inmediata o previa al momento de comunicar un despido, para que la desactivación de credenciales (correo, VPN, accesos físicos) ocurra mientras el empleado es notificado.

Devolución de Activos: El empleado no recibirá su liquidación final hasta que devuelva todos los equipos (laptops, teléfonos corporativos, tokens de seguridad física, tarjetas de acceso y uniformes).

Entrevista de Salida y Recordatorio Legal: Durante la salida, RR.HH. debe entregar una copia del NDA original firmado por el empleado, recordando explícitamente que la prohibición de compartir información confidencial del banco o llevarse carteras de clientes se mantiene vigente de forma indefinida tras la terminación del contrato.